

GUÍA METODOLÓGICA DETALLADA

Kit de Encuesta FISMA 2025 — Diagnóstico de Madurez en Ciberseguridad

Documento de referencia para investigadores, administradores de encuesta y analistas

1. FUNDAMENTOS METODOLÓGICOS

1.1 Diseño del Instrumento

Esta encuesta está diseñada como un **instrumento de diagnóstico mixto** que combina:

- Escala Likert de madurez ordinal (5 niveles): Para la mayoría de preguntas de opción múltiple, las respuestas A-E siguen una escala de madurez ascendente (de menos a más maduro), directamente alineada con el modelo de 5 niveles FISMA/NIST (Ad Hoc → Defined → Consistently Implemented → Managed and Measurable → Optimized).
- Preguntas de opción múltiple no ordinales: Para variables nominales (tipo de entidad, sector, vector de ataque) donde no existe orden jerárquico inherente.
- Preguntas abiertas: Para captura de contexto cualitativo que los formatos cerrados no pueden capturar.
- Escala numérica (P59): Para autoevaluación de cultura organizativa.

1.2 Fundamento Teórico

El instrumento se fundamenta en cuatro marcos normativos y metodológicos primarios:

Marco	Versión utilizada	Función en el instrumento
NIST Cybersecurity Framework (CSF)	2.0 (febrero 2024)	Estructura de los 6 funciones y 10 dominios
FISMA IG Reporting Metrics	FY2025 v2.0 (3 abril 2025)	25 indicadores de referencia para las preguntas
ENS — Esquema Nacional de Seguridad	RD 311/2022	Marco normativo español; correlaciones normativas
Directiva NIS2 + Anteproyecto Ley España	2022/0383/EU + enero 2025	Requisitos de notificación, gobernanza, cadena de suministro

1.3 Población Objetivo

La encuesta está diseñada para su aplicación a tres poblaciones distintas:

Población A — Administraciones Públicas Autonómicas y Locales:

Objetivo principal del estudio. Incluye organismos de Comunidades Autónomas (consejerías, agencias, entes instrumentales), Diputaciones y Ayuntamientos de más de 20.000 habitantes.

Población B — Empresas privadas proveedoras del sector público:

Entidades privadas que prestan servicios TIC a las AAPP o que gestionan infraestructuras críticas bajo ENS o NIS2.

Población C — Infraestructuras críticas y entidades esenciales:

Operadores de infraestructuras críticas (CNPIC), entidades esenciales e importantes NIS2 en los 18 sectores definidos por la Directiva.

2. PROCESO DE ADMINISTRACIÓN

2.1 Modalidades de Aplicación

Modalidad	Descripción	Tiempo estimado	Población recomendada
Autoadministración online	Formulario digital (Typeform, LimeSurvey, Microsoft Forms)	45-60 min	Todas
Entrevista asistida	Investigador facilita y aclara dudas en tiempo real	60-90 min	Pop. A: entidades pequeñas
Versión abreviada	Módulos I, II, IX y XII únicamente (15 preguntas)	20-25 min	Primera criba; screening
Versión directiva	Módulos I, II, XI, XII y XIV (20 preguntas)	25-30 min	Perfiles de alta dirección

2.2 Instrucciones para el Administrador

Antes de distribuir la encuesta:

1. Verificar que el respondente tiene el perfil adecuado para responder al módulo (ver tabla de correspondencia en Sección 5).
2. Garantizar que el respondente entiende que no se busca la respuesta correcta sino la respuesta honesta; las respuestas en los niveles inferiores no son penalizadas y son más valiosas para el diagnóstico.
3. Informar sobre el tratamiento de datos y obtener consentimiento explícito.
4. Asignar un código de organización para preservar el anonimato en el análisis agregado.

Durante la administración:

- No sugerir respuestas ni interpretar las preguntas de forma directiva.
- Anotar observaciones contextuales que el respondente verbalice y que enriquezcan el análisis.
- Registrar el tiempo de cumplimentación para calibración del instrumento en posteriores aplicaciones.

Después de la recogida:

- Validar que no existan respuestas en blanco en los módulos obligatorios (I, IX, XII).
- Codificar las respuestas abiertas mediante análisis temático cualitativo.
- Incorporar los datos al sistema de cálculo del IGM (ver Sección 4).

3. SISTEMA DE CODIFICACIÓN Y PUNTUACIÓN

3.1 Escala de Madurez por Respuesta

Para las preguntas de escala ordinal (mayoría del instrumento):

Respuesta	Nivel FISMA	Puntuación base
A	Nivel 4-5 (Managed & Measurable / Optimized)	4-5 puntos
B	Nivel 3-4 (Consistently Implemented / parcialmente Managed)	3-4 puntos
C	Nivel 2-3 (Defined / parcialmente Consistently Implemented)	2-3 puntos
D	Nivel 1-2 (Ad Hoc / parcialmente Defined)	1-2 puntos
E	Nivel 1 (Ad Hoc)	1 punto

Nota importante: La puntuación exacta por pregunta está detallada en la Plantilla Excel (documento e del Kit). Las preguntas de opción múltiple no ordinal (P52 vector de ataque, P46 obstáculos NIS2) no puntúan en la escala IGM pero alimentan el análisis cualitativo.

3.2 Ponderación por Dominio

Los dominios FISMA FY2025 tienen ponderaciones diferenciadas en el cálculo del **Índice Global de Madurez (IGM)** según su relevancia estratégica y el perfil de la organización:

Módulo / Dominio	Ponderación estándar (AAPP)	Ponderación ajustada (Infra. Crítica)
I — Gobernanza	15%	12%
II — C-SCRM	10%	15%
III — Gestión de Riesgos/Activos	10%	10%
IV — Gestión de Configuración	8%	8%
V — IDAM / Zero Trust	12%	10%
VI — Protección de Datos	10%	8%
VII — Formación	5%	5%
VIII — Monitorización Continua	12%	15%
IX — Respuesta a Incidentes	10%	12%
X — Continuidad de Negocio	8%	5%
TOTAL	100%	100%

3.3 Cálculo del IGM (Índice Global de Madurez)

El IGM se calcula como la suma ponderada de las puntuaciones medias por módulo:

$$\text{IGM} = \sum (\text{Puntuación_media_módulo_i} \times \text{Ponderación_i})$$

Escala IGM resultante:

Rango IGM	Nivel de madurez	Interpretación
1.0 - 1.5	Ad Hoc	Intervención urgente requerida
1.5 - 2.5	Defined	Mejora prioritaria; riesgo elevado
2.5 - 3.5	Consistently Implemented	Por debajo del umbral de efectividad
3.5 - 4.5	Managed & Measurable	Umbral de efectividad FISMA
4.5 - 5.0	Optimized	Referencia de excelencia

4. CÁLCULO DEL ROI EN CIBERSEGURIDAD

4.1 Marco Conceptual

El **Retorno sobre la Inversión en Ciberseguridad (ROSI)** se calcula mediante la metodología del **Factor de Riesgo Anual (ALE)**:

$$\text{ROSI} = (\text{ALE}_{\text{antes}} - \text{ALE}_{\text{después}} - \text{Coste_control}) / \text{Coste_control}$$

Donde:

- ALE (Annual Loss Expectancy) = ARO × SLE
- ARO (Annual Rate of Occurrence) = probabilidad anualizada del incidente
- SLE (Single Loss Expectancy) = impacto económico estimado de un incidente

4.2 Variables de Entrada (alimentadas por la encuesta)

- P51 (Presupuesto de ciberseguridad): variable de coste de control.
- P52 (Incidentes sufridos): variable proxy para ARO.
- P50 (Nivel de madurez autoevaluado): variable de ajuste del SLE.
- P41-P43 (RTO/RPO/BCP): variables de impacto económico en continuidad.

4.3 Benchmarks de Referencia para Cálculo ALE

Los benchmarks publicados utilizados como referencia en la Plantilla Excel:

- Coste medio incidente de seguridad PYME España 2025: entre 35.000€ y 75.000€ (INCIBE 2025).
- Coste medio ransomware empresa mediana (>500 empleados) en España: entre 180.000€ y 1,2M€.
- Presupuesto mediano de ciberseguridad entidades NIS UE: 1,5M€ (ENISA NIS Investments 2025).
- Reducción de riesgo por incremento de madurez de nivel 2 a nivel 4: estimada en 60-70% (NIST NICE Framework).

5. CORRESPONDENCIA PERFIL-MÓDULO

5.1 Módulos Obligatorios por Perfil

Perfil	Módulos obligatorios	Módulos opcionales
CISO / Responsable de Seguridad	I, II, III, IV, V, VI, VIII, IX, X, XII	VII, XI, XIII, XIV
CIO / Director TI	I, III, IV, V, VIII, IX, X, XII	II, VI, XI, XIII, XIV
Director General / Consejo	I, II, IX, XI, XII, XIV	Todos los demás
DPO / Responsable Cumplimiento	I, II, VI, XI, XII	III, IV, IX, XIV
Técnico de Ciberseguridad	III, IV, V, VIII, IX, X	I, II, XI, XII, XIII

6. TRATAMIENTO DE DATOS Y ANÁLISIS

6.1 Análisis Cuantitativo

5. Análisis univariado: Distribución de frecuencias por pregunta y opción de respuesta; medias, medianas y modas por módulo.
6. Análisis bivariado: Correlaciones entre IGM y variables de caracterización (tipo de entidad, tamaño, CC.AA., sector).
7. Análisis comparativo: Benchmarking entre organizaciones, comunidades autónomas y sectores.
8. Análisis de regresión: Identificación de predictores del nivel de madurez global (qué variables organizativas correlacionan más fuertemente con el IGM).

6.2 Análisis Cualitativo

Las preguntas abiertas (P56, P57, P58) se analizan mediante:

9. Análisis temático inductivo: Identificación de categorías emergentes en los obstáculos identificados.
10. Frecuencia de códigos: Cuantificación de la aparición de temas para triangulación con resultados cuantitativos.
11. Análisis de sentimiento: Evaluación del tono y la urgencia percibida por los respondentes.

6.3 Validación del Instrumento

Para garantizar la fiabilidad y validez del instrumento en una aplicación a gran escala:

- Alfa de Cronbach por módulo: objetivo $\alpha > 0,75$ por módulo para confirmar consistencia interna.
- Validez de contenido: Panel de expertos (CISO, académicos, reguladores) para revisión de la cobertura de los dominios FISMA.
- Prueba piloto: Aplicación a una muestra de 15-20 organizaciones antes del despliegue completo; ajuste de redacción y opciones de respuesta según feedback.
- Test-retest: Reaplicación a un subconjunto de 10 organizaciones pasadas 4 semanas para verificar estabilidad temporal.

7. CONSIDERACIONES ÉTICAS Y LEGALES

7.1 Protección de Datos

- La encuesta trata datos personales (datos profesionales del respondente) y potencialmente datos sensibles sobre la postura de seguridad de la organización.
- El tratamiento se basa en el consentimiento explícito del respondente (Art. 6.1.a RGPD).
- Los datos de las organizaciones se anonimizarán mediante código antes del análisis y publicación.
- Los datos personales de los respondentes se eliminarán tras la finalización del análisis, conforme al principio de limitación del plazo de conservación.
- Se designará un Responsable del Tratamiento (entidad investigadora) y, si aplica, un DPO conforme al Art. 37 RGPD.

7.2 Seguridad de los Datos de la Encuesta

- La plataforma de encuesta debe cumplir con ENS categoría Media como mínimo o disponer de certificación equivalente (ISO 27001, SOC2 Tipo II).
- Los datos deben transmitirse con cifrado TLS 1.2+ y almacenarse cifrados en reposo.
- El acceso a los datos en bruto se limitará al equipo investigador con control de acceso basado en roles.

8. PLAN DE DIFUSIÓN Y RECOGIDA

8.1 Cronograma Recomendado

Fase	Actividades	Duración
Preparación	Revisión por panel de expertos; ajuste instrumento; aprobación ética	3 semanas
Piloto	Aplicación a 15-20 organizaciones; análisis de feedback	2 semanas
Ajuste	Incorporación de mejoras; versión final del instrumento	1 semana
Difusión	Envío invitaciones; recordatorios; seguimiento	6-8 semanas
Análisis	Procesamiento datos; análisis estadístico y cualitativo	4 semanas
Reporte	Elaboración informes; revisión; publicación	3 semanas
Total		~20 semanas

8.2 Tamaño Muestral Recomendado

Para resultados estadísticamente representativos por Comunidad Autónoma (con error máximo $\pm 5\%$, nivel de confianza 95%):

- Muestra mínima por CC.AA.: 384 organizaciones (para población infinita).
- Muestra ajustada para AAPP autonómicas y locales: 200-250 respondentes por CC.AA. (dado el número finito de entidades).
- Muestra total objetivo a nivel nacional: 3.500-4.500 respondentes.
- Muestra mínima viable para análisis descriptivo: 150 respondentes (resultados orientativos).

Kit de Encuesta FISMA 2025 — Guía Metodológica · Versión 1.0 · Abril 2026